

Experiment 5 – SCA Demonstration Using FOSSA

Aim

To identify open-source dependencies in a sample project and analyze their vulnerabilities and license compliance using FOSSA SCA.

Procedure

- 1. Open PowerShell.
- 2. Install FOSSA CLI and verify the installation.
- 3. Log in to FOSSA and generate an API key; do not expose the key.
- 4. Set FOSSA_API_KEY in PowerShell.
- 5. Create/open the sample project.
- 6. For the Node.js example, initialize the project and install lodash@4.17.20.
- 7. Run fossa analyze from the project root.
- 8. Run fossa test.
- 9. Open the FOSSA dashboard and review dependencies, CVEs, severity, affected versions, remediation and licenses.
- 10. If required, generate SPDX SBOM using the CLI and CycloneDX SBOM through the web UI.

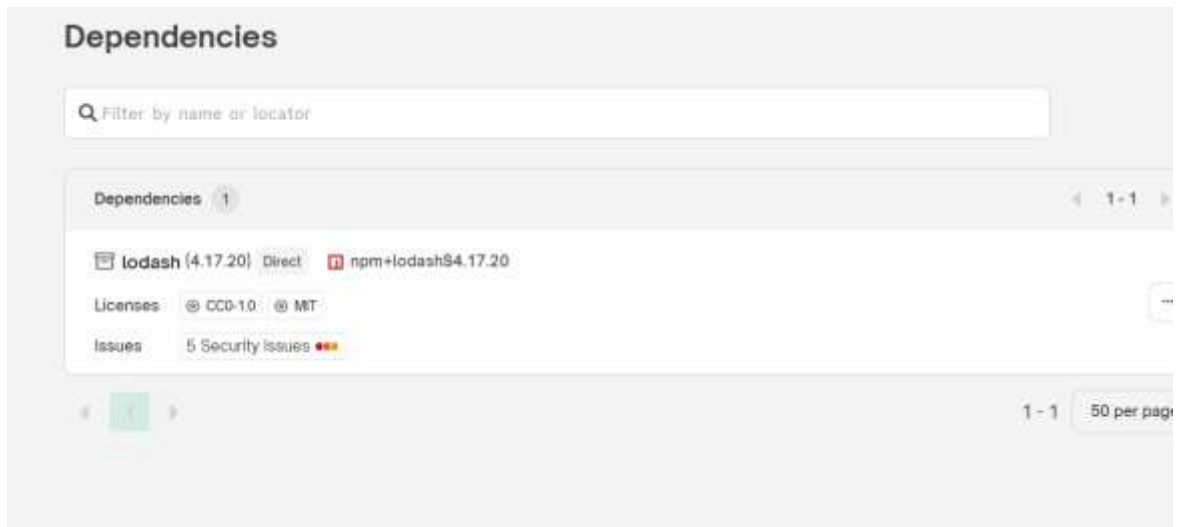
Commands

```
Set-ExecutionPolicy Bypass -Scope Process -Force; iex ((New-Object
System.Net.WebClient).DownloadString('https://raw.githubusercontent.com/fo
ssa/fofoss-cli/master/install.ps1'))
$env:FOSSA_API_KEY="<your_api_key>"
cd $HOME\Desktop
mkdir fossa-sca-project
cd fossa-sca-project
npm init -y
npm install lodash@4.17.20
npm list lodash
fossa analyze
fossa test
fossa report attribution --format spdx
fossa report attribution --format spdx-json
fossa report attribution --format spdx > sbom-spdx.txt
fossa report attribution --format spdx-json > sbom-spdx.json
```

Output:

The screenshot displays the FOSSA SCA Project interface for a project named 'fossa-sca-project'. The interface includes a navigation bar with tabs for Projects, Issues, Reports, Policies, and Support. The main content area shows a summary of issues, with a section titled 'Issues in Master' indicating 5 issues. A red box highlights '5 Vulnerabilities' with a '25 Review & Fix' button. Below this, there is a 'Live Project Compliance Report' section. On the right side, there are two numbered boxes (1 and 2) and a 'Team Access' section.

```
{
  "$schema": "http://cyclonedx.org/schema/bom-1.7.schema.json",
  "bomFormat": "CycloneDX",
  "specVersion": "1.7",
  "version": 1,
  "serialNumber": "urn:uuid:54cb586-dd87-443e-b19b-ab58986c092",
  "metadata": {
    "timestamp": "2023-10-06T17:09:41.174Z",
    "tools": {
      "components": [
        {
          "type": "application",
          "name": "FOSSA",
          "version": "4.34.135",
          "manufacturer": {
            "name": "FOSSA, Inc.",
            "address": {
              "country": "US",
              "region": "CA",
              "locality": "San Francisco",
              "postalCode": "94105",
              "streetAddress": "595 Market St. Fl 10"
            },
            "url": [
              "https://fossa.com"
            ]
          }
        }
      ]
    },
    "authors": [
      {
        "name": "rajulakshai engineering college"
      }
    ],
    "component": {
      "name": "fossascan"
    }
  }
}
```



Result:

Thus identifying open-source dependencies in a sample project and analyze their vulnerabilities and license compliance using FOSSA SCA was done successfully.